Account-owner query review

Application Security | APPSEC-2026-112

Review date	Component	Reviewer
November 2, 2026	own_tickets reference query	Application Security

Scope

Review of the own_tickets query reproduced below. The scope is query construction and parameter binding for the account-owner filter. Runtime routing and other database operations are not included in this review.

Implementation reviewed

```
def own_tickets(connection, actor_id):
    return connection.execute(
        "SELECT id, title FROM tickets_ticket WHERE owner_id = ?",
        (actor_id,),
    ).fetchall()
```

Query construction

The SQL statement is a fixed string. The owner identifier is supplied separately as a bound parameter. The database driver receives the value as data rather than concatenating it into the SQL statement.

Check	Observed result
Parameterized owner lookup	Confirmed
String concatenation in this lookup	Not present
SQL-injection finding for this lookup	Not confirmed

Follow-up

Retain the parameterized query when modifying the lookup. Review changes to query construction during code review. Other endpoints and administrative reports were outside the scope of this review.